

# Risk Register

---

This register tracks the risks identified for the storage capacity management and deviation-detection system across the heterogeneous multi-OS fleet (AIX, all Linux distributions, and Windows Server, all first-class and delivered together). It covers data-quality, schema-integrity, collection, scalability, security, compliance, forecasting, standards, AI/agentive, and delivery risks. The project is in the scoping / specification phase, so every risk currently reflects a design-time or anticipated operational concern rather than an incident in a running system.

The severity column combines likelihood and impact. Mitigations describe the planned design or operational response; owners and statuses are tracked as the program progresses. All risks below align with the canonical data model: exact bytes everywhere, a single OS-agnostic storage collection schema, one envelope file per collection run containing a `hosts[]` array, weak linkage by keys ( `backing_ref` / `group_ref` ), and downstream derivation of `storage_class` , percentages, growth rates, deviations, and severities.

## Risk register

| Id     | Risk                                                                                                           | Category           | Likelihood | Impact | Severity | Mitigation                                                                                                                                                                                                                                 | Owner             | Status |
|--------|----------------------------------------------------------------------------------------------------------------|--------------------|------------|--------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------|--------|
| RSK-01 | GB/GiB rounding and unit drift in reports; values diverge from the canonical exact-bytes representation        | Data Quality       | Medium     | Medium | Medium   | Store and compute always in exact bytes (a schema invariant); round only at the presentation layer; add unit assertions in validation                                                                                                      | Data Engineer     | Open   |
| RSK-02 | Missing AIX golden image / reference standard; nothing to deviate against for rootvg/datavg/JFS2               | Standards          | Medium     | High   | High     | Build the AIX reference standard early; use layered inheritance (OS-family -> distribution -> version -> role); flag hosts with no applicable standard                                                                                     | Standards Owner   | Open   |
| RSK-03 | Inconsistent naming (VG / LV / mount / host) defeats grouping and standard matching                            | Data Quality       | High       | Medium | High     | Normalization plus a canonical naming dictionary; fuzzy matching with confidence-based auto-confirmation, flagging low-confidence matches distinctly; record both raw and normalized values                                                | Data Engineer     | Open   |
| RSK-04 | False positives / negatives in deviation detection erode trust and hide real risk                              | Detection Accuracy | High       | High   | Critical | Calibrate thresholds per OS / fstype / role; use severity tiers; automatically flag low-confidence / high-impact findings, withhold them from auto-confirmation, and surface them distinctly; track precision/recall against a labeled set | ML/Detection Lead | Open   |
| RSK-05 | LLM hallucination (LangGraph agents invent mounts, standards, or remediations)                                 | AI/Agentic         | Medium     | High   | High     | Ground every claim in the collected data; constrain tool outputs; cite schema fields; let deterministic checks gate the LLM narrative; recommend-only with the system never executing remediation                                          | AI Lead           | Open   |
| RSK-06 | Broken filesystem-to-topology linkage ( group_ref / backing_ref not resolving) breaks storage_class derivation | Schema Integrity   | Medium     | High   | High     | Run referential-integrity validation on every collection run; raise orphan-reference alerts; derive storage_class only when links resolve, otherwise mark it unknown                                                                       | Data Engineer     | Open   |
| RSK-07 | Single-run view: no history means no growth trend and no forecasting                                           | Forecasting        | High       | High   | Critical | Persist an append-only time series of collection runs; require at least N points before forecasting; gate objectives O3 and O4 on history availability                                                                                     | Data Engineer     | Open   |

| Id     | Risk                                                                                                                 | Category        | Likelihood | Impact | Severity | Mitigation                                                                                                                                                                                                                                  | Owner               | Status |
|--------|----------------------------------------------------------------------------------------------------------------------|-----------------|------------|--------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|--------|
| RSK-08 | Privacy / scope creep: collection captures sensitive content beyond non-sensitive metadata                           | Compliance      | Low        | High   | High     | Enforce the metadata-only contract; collect non-sensitive aggregates only; keep ACL summaries non-sensitive; review collection commands; conduct a DLP (data-loss-prevention) review                                                        | Security/Compliance | Open   |
| RSK-09 | Command variance across OS versions yields inconsistent or unparseable output                                        | Collection      | High       | Medium | High     | Maintain a version-aware command matrix; provide a parser per command/version; record <code>collection_method</code> and <code>scan_confidence</code> ; fail soft per field                                                                 | Collection Eng      | Open   |
| RSK-10 | Data volume at >= 500 hosts x fields x runs overwhelms storage and processing                                        | Scalability     | Medium     | Medium | Medium   | Deliver one envelope file per collection run (a <code>hosts[]</code> array, one document per server); back history with a columnar / partitioned store and use JSONL for very large fleets; process incrementally; apply a retention policy | Platform Eng        | Open   |
| RSK-11 | Incomplete collection (host unreachable, partial scan) skews the fleet view                                          | Collection      | High       | Medium | High     | Record <code>scan_confidence</code> and completeness flags; exclude partial hosts from aggregates; retry and backfill; surface coverage metrics                                                                                             | Collection Eng      | Open   |
| RSK-12 | Reference / standards drift: standards age and diverge from real fleet state                                         | Standards       | Medium     | Medium | Medium   | Version standards with effective dates; set a periodic review cadence; produce a standards-vs-fleet drift report                                                                                                                            | Standards Owner     | Open   |
| RSK-13 | Triage bottleneck: findings cannot be prioritized fast enough at fleet scale                                         | Operational     | Medium     | Medium | Medium   | Auto-triage by severity and confidence; batch low-risk findings; automatically flag and surface high-impact findings distinctly; feed outcomes back to tune thresholds                                                                      | Operations Lead     | Open   |
| RSK-14 | Data-at-rest security of the storage inventory (still infrastructure-sensitive even though content is non-sensitive) | Security        | Low        | High   | High     | Encrypt at rest; enforce access control plus audit; apply least privilege; segregate from production credentials                                                                                                                            | Security/Compliance | Open   |
| RSK-15 | OS-landscape change (new distribution / version / Windows build) outpaces collectors and standards                   | Maintainability | Medium     | Medium | Medium   | Use pluggable collectors and standards; maintain an onboarding checklist for each new OS; set a backlog SLA (service-level agreement) for new platforms                                                                                     | Platform Eng        | Open   |
| RSK-16 | Over-reliance on automation: remediation acted on without sufficient                                                 | AI/Agentic      | Medium     | High   | High     | Recommend-only mode in which the system never executes remediation; deterministic grounding of                                                                                                                                              | AI Lead             | Open   |

| Id     | Risk                                                                                                                                                                                                      | Category         | Likelihood | Impact | Severity | Mitigation                                                                                                                                                                                                                                                        | Owner                | Status |
|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|------------|--------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|--------|
|        | grounding                                                                                                                                                                                                 |                  |            |        |          | every finding; keep an immutable audit trail; define clear automation boundaries                                                                                                                                                                                  |                      |        |
| RSK-17 | Windows model divergence: no LVM; mapping NTFS / ReFS volumes and Storage Spaces onto the OS-agnostic schema (pool = group, virtual disk = volume, basic disk -> partitions-as-volumes with empty groups) | Schema Integrity | Medium     | High   | High     | Define explicit Windows mapping rules using the <code>*_kind</code> discriminators; treat the basic-disk path as yielding empty groups by design; run conformance tests on real Windows runs; derive <code>storage_class = system</code> for the C: / boot volume | Windows Platform Eng | Open   |
| RSK-18 | WinRM authentication and security: agentless reach needs credentials, encryption, and trusted transport to >= 500 Windows hosts                                                                           | Security         | Medium     | High   | High     | Use WinRM over HTTPS / Kerberos; use a vaulted least-privilege service account; allow no plaintext credentials; scope per host; rotate and audit; apply network segmentation                                                                                      | Security/Compliance  | Open   |
| RSK-19 | btrfs subvolume / snapshot size accounting: plain <code>df</code> is misleading, producing wrong used ratios and wrong forecasts on SUSE / SLES                                                           | Data Quality     | High       | High   | Critical | Use <code>btrfs filesystem usage / qgroups</code> for true bytes (never plain <code>df</code> on btrfs); branch the collector by fstype; validate against allocated extents                                                                                       | Collection Eng       | Open   |
| RSK-20 | OS-agnostic mapping errors: <code>group_ref</code> / <code>backing_ref</code> semantics differ across AIX / Linux / Windows and get crossed                                                               | Schema Integrity | Medium     | High   | High     | Maintain a per-platform mapping spec with key conventions; run cross-platform referential-integrity tests; use a canonical reference namespace; reject ambiguous links                                                                                            | Data Engineer        | Open   |
| RSK-21 | Standards explosion across OS x distribution x version x role (combinatorial standard set)                                                                                                                | Standards        | High       | Medium | High     | Use layered inheritance (defaults at OS-family, overridden down to role/version); store only deltas; run inheritance-resolution tests                                                                                                                             | Standards Owner      | Open   |
| RSK-22 | Windows ACL-summary vs Unix mount-option compliance-model mismatch ( <code>access_model</code> differs: ntfs-acl vs posix-mount-options)                                                                  | Compliance       | Medium     | Medium | Medium   | Use two compliance evaluators keyed on <code>access_model</code> ; map intent (for example no-exec, restricted-write) to per-model checks; never apply mount-option rules to NTFS                                                                                 | Security/Compliance  | Open   |

| Id     | Risk                                                                                                                                        | Category | Likelihood | Impact | Severity | Mitigation                                                                                                                                                                                                                                                          | Owner        | Status |
|--------|---------------------------------------------------------------------------------------------------------------------------------------------|----------|------------|--------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|--------|
| RSK-23 | Simultaneous multi-OS delivery (AIX + all Linux distributions + Windows, all first-class in a single release) inflates scope and complexity | Delivery | High       | High   | Critical | Anchor everything on the shared OS-agnostic schema with pluggable per-OS collectors and standards; run parallel workstreams against common contracts; stage enablement behind one schema; define an explicit MVP (minimum viable product) per objective on every OS | Program Lead | Open   |

## Top risks and response

The following narrative covers the Critical and High risks that most threaten the objectives and require the most deliberate response.

- **RSK-04 (False positives / negatives): Critical.** Detection errors directly defeat objectives O1 (deviation detection) and O5 (risk reduction / compliance) and destroy operator trust. Response: per-OS / fstype / role threshold calibration, severity tiers, automatic flagging of high-impact deviations (withheld from auto-confirmation and surfaced distinctly via confidence-based triage), and continuous precision/recall tracking against a labeled set before any auto-action.
- **RSK-07 (Single-run, no history): Critical.** Without a time series there is no growth trend, so objectives O3 (reliability / full-filesystem prevention) and O4 (operational efficiency / forecasting) cannot be met. Response: persist an append-only series of collection runs from day one, require a minimum number of points before forecasting, and gate growth-dependent objectives on history availability.
- **RSK-19 (btrfs size accounting on SUSE / SLES): Critical.** Plain `df` on btrfs with subvolumes and snapshots reports wrong bytes, corrupting every downstream used ratio, forecast, and deviation. Response: an fstype-aware collector that uses `btrfs filesystem usage / qgroups` (never plain `df`), validated against allocated extents, with the result normalized to exact bytes in the schema.
- **RSK-23 (Simultaneous multi-OS delivery): Critical.** Delivering AIX, all Linux distributions, and Windows as first-class in a single release multiplies scope and integration risk. Response: anchor everything on the single OS-agnostic schema with pluggable per-OS collectors and standards, run parallel workstreams against common contracts, and define an explicit MVP per objective on every OS.
- **RSK-17 / RSK-18 / RSK-22 (Windows first-class set): High.** Windows joins now at full depth: schema mapping (no LVM; Storage Spaces pools and virtual disks map to groups and volumes via the `*_kind` discriminators, while basic disks yield partitions-as-volumes with empty groups), agentless WinRM security, and a distinct ACL-based compliance model. Response: explicit Windows mapping rules with conformance tests on real runs, WinRM over HTTPS / Kerberos with vaulted least-privilege accounts, and a separate compliance evaluator keyed on `access_model` so NTFS ACL intent is never judged by POSIX mount-option rules.

- **RSK-02 / RSK-21 (Standards coverage and explosion): High.** Missing reference images (notably AIX) mean there is nothing to deviate against, while the OS x distribution x version x role matrix risks a combinatorial standards blow-up. Response: build the reference standards early and tame the combinatorics with layered inheritance, storing only deltas from OS-family defaults down to role and version. The reference standards / golden images are an explicit upcoming deliverable outside this document set.
- **RSK-05 / RSK-16 (LLM hallucination and over-automation): High.** Agentic LangGraph reasoning can invent facts or recommend actions without sufficient grounding. Response: ground every assertion in the collected data with deterministic checks gating the LLM narrative, operate in recommend-only mode in which the system never executes remediation, and keep an immutable audit trail. The deterministic rules perform all measurement and detection; the LLM layer only explains, prioritizes, and recommends. People read the reports and act on them outside the system; there is no human step inside the pipeline.